
Seguretat Informatica (SI)

Infraestructura PKI

René Serral (forked from: Davide Careglio)

Fonts:

Jordi Nin, "Certificates", Computer Security, 2014

Francisco Jordan, "PKI and Certificates", Computer Security, 2018

Jaime Delgado, "Certificates", Computer Security, 2017

Temari

- Tema 1. Introducció
- Tema 2. Criptografia
- **Tema 3. Infraestructura PKI**
- Tema 4. Seguretat en les aplicacions
- Tema 5. Seguretat als sistemes operatius
- Tema 6. Anàlisi forense

Tema 3. Índex

- **3.1 - Conceptes bàsics**
- 3.2 - Components d'una PKI
- 3.3 - Models de confiança (trust models)
- 3.4 - Certificats X.509
- 3.5 - Public-Key Cryptography Standards (PKCS)

Conceptes bàsics

- La criptografia pública permet l'intercanvi de missatges secrets i autèntics
 - Secrets: nomé el destí amb la clau privada sap desxifrar-los
 - Autèntics: són els missatges originals de l'origen, i.e., es garanteix que no han sigut modificat
- Només cal saber la clau pública del destí per transmetre aquests missatges
- Però ...
- Com podem estar segurs que la clau pública que hem usat és realment del destí que volem?
- Algú podria haver manipulat aquesta clau o haver-la substituït per una altra

Primera Proposta

- En el 1976, Diffie-Hellman proposa l'ús d'un únic repositori segur que emmagatzemi totes les claus públiques
- Problemes
 - Poc rendiment (coll d'ampolla)
 - Requisits de seguretat extrems (concentració en un únic punt)
 - Necessitat de backup (rèplica de les dades) que requereix la transmissió de noves dades constantment: possible manipulació, pèrdua, inserció, etc.

Segona Proposta

- Al 1978, Kohnfelder va considerar la idea d'usar autoritats de confiança centralitzades
- Proposa la creació d'un conjunt de registres de dades signades (certificats) que permetin un sistema de distribució de claus públiques de confiança
- Un certificat digital és una estructura de dades que conté
 - La identitat del propietari (pot ser persona física, organisme o empresa)
 - La seva clau pública
 - La firma digital d'una entitat de confiança que certifica que la clau pública és d'aquest propietari que després tindrà al seu poder la clau privada corresponent

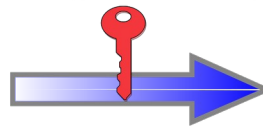
Segona Proposta¹

- La certificació que la identitat del propietari i de la clau pública és correcta recau en una autoritat de confiança
- De forma que la confiança en aquesta autoritat s'“estén” a la clau pública
 - i.e., la clau pública és de confiança

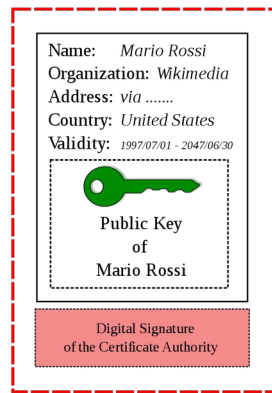
Identity Information and
Public Key of Mario Rossi



Certificate Authority
verifies the identity of Mario Rossi
and encrypts with its Private Key



Certificate of Mario Rossi



Digitally Signed by
Certificate Authority

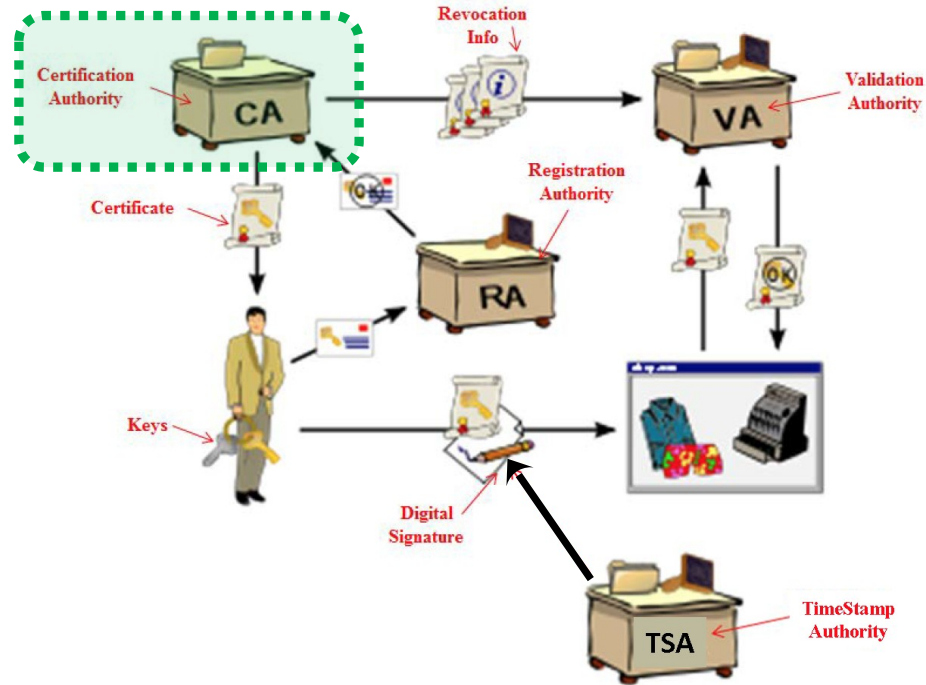
Tema 3. Índex

- 3.1 - Conceptes bàsics
- **3.2 - Components d'una PKI**
- 3.3 - Models de confiança (trust models)
- 3.4 - Certificats X.509
- 3.5 - Public-Key Cryptography Standards (PKCS)

Components d'una PKI

- La Public Key Infrastructure (PKI) és el conjunt d'ordinadors, software, individus, polítiques i procediments necessaris per a crear i administrar els certificats digitals basats en criptografia de clau pública
- El objectiu és la gestió eficient i fiable dels certificats digitals i les seves claus criptogràfiques

Estructura de la PKI



Certification Authority (CA)

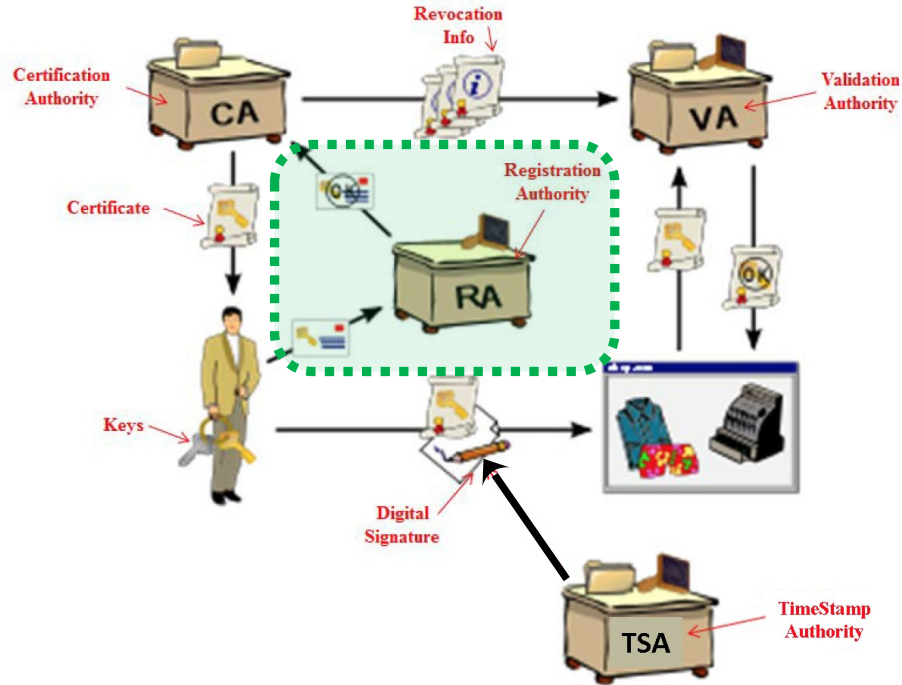
- Per què es necessiten les CA
 - Són les Trusted Third Party (TTP)
 - Encarregades d'emetre els certificats digitals
 - Opcionalment poden generar les claus públiques/privades
 - Han de mantenir les seves pròpies claus públiques/privades molt protegides (recordar que les CA firmen digitalment els certificats)
 - Típicament guardades en hardware criptogràfic sense connectivitat a la xarxa i amb polítiques d'accés físic molt restrictives
- Una PKI pot tenir més d'una CA
- Però ... Qui certifica que una CA és de confiança?
 - Altres CA
 - La mateixa CA

} Veurem els models més endavant

Exemples de CA a Espanya

- Direcció General de la Policia (DNle)
- Fàbrica Nacional de Moneda i Timbre (FNMT)
- Agència Catalana de Certificació (CATCert)
- Firma professional
- Autoritat de Certificació de la Abogacia (ACA)
- ...

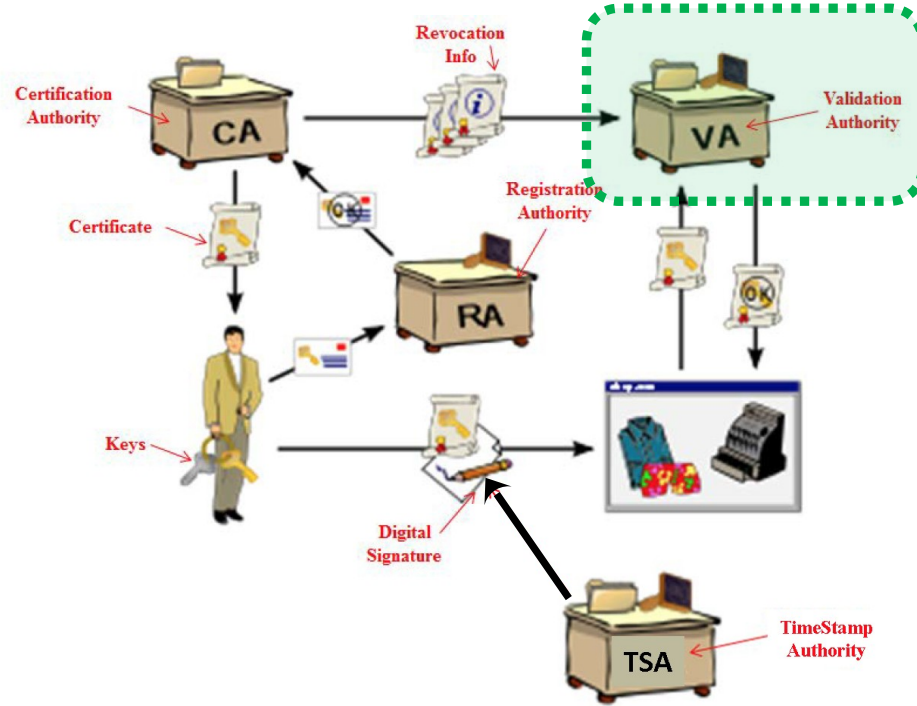
Estructura de la PKI



Registration Authority (RA)

- Una RA s'encarregarà de verificar la relació entre la clau pública i la identitat del propietari
- Per exemple a Espanya, la RA de la FNMT és la Agència Tributaria local
- La RA és un component opcional d'una PKI
 - Serveix per a que una CA no s'ocupi de temes administratius
 - Si no hi ha una RA, la CA fa també de RA

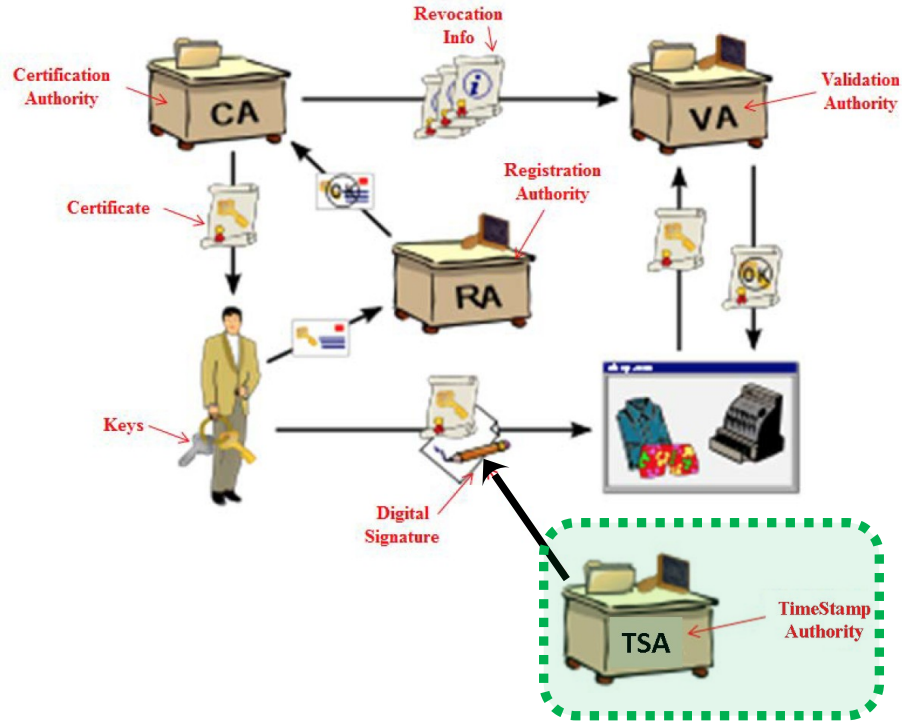
Estructura de la PKI



Validation Authority (VA)

- Una VA s'encarrega de verificar la validesa dels certificats digitals
 - Pot ser directament la CA o
 - Una entitat externa
- Proporciona informació en temps real sobre l'estat d'un certificat (**valid, suspend, revoked, unknown**)
- Es fan servir protocols de validació per a conèixer aquest estat actual
 - Online Certificate Status Protocol (OCSP)
 - Simple Certificate Validation Protocol (SCVP)

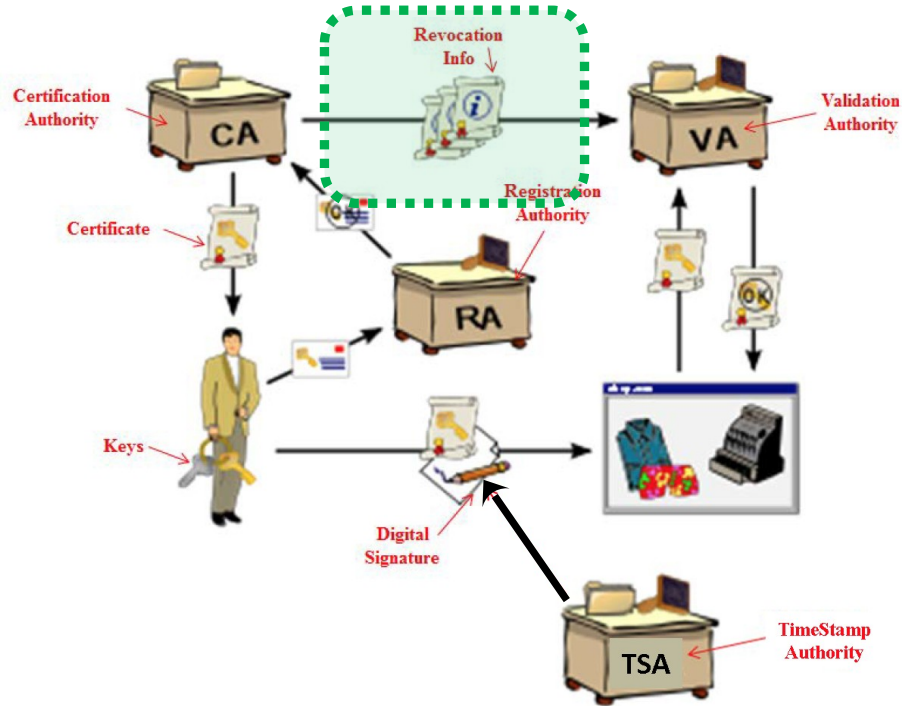
Estructura de la PKI



Time Stamping Authority (TSA)

- Una TSA s'encarrega de firmar un missatge per a marcar en quin moment es va generar
- Els escenaris en els que les TSA son molt importants
 - Verificació de un documento firmat digitalment. Si el certificat corresponent ha sigut revocat, la marca de temps permet decidir si el document va ser firmat abans de la revocació
 - Data límit d'entrega de documents. La marca de temps permet verificar si el document es va entregar a temps
 - Auditories. Les marques de temps permeten datar totes las entrades passades (p.e., factures, correus, documents)

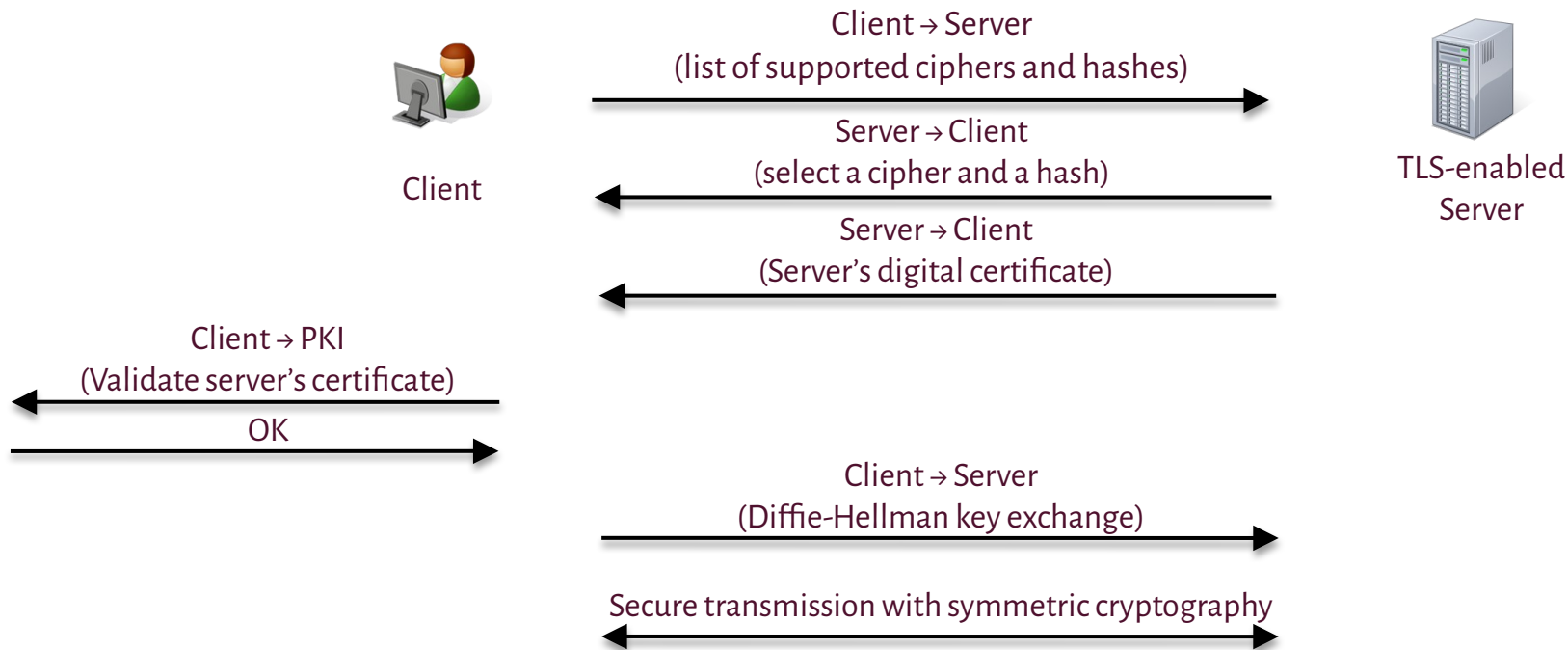
Estructura de la PKI



Repositoris

- Els **repositoris** són estructures de dades per a emmagatzemar tota la informació sobre una PKI
- Els dos repositoris més importants són
 - El repositori de certificats
 - El repositori de la llista de certificacions en revocació (CRL). Una CRL és una llista de certificats que s'han revocat i, per tant, no poden ser acceptats
- Els **directories** són estructures de repositori usades normalment amb una PKI
 - Són bases de dades dissenyades per emmagatzemar una gran quantitat d'objectes tipificats (com certificats)
 - Estan optimitzats per a llegir, navegar i buscar

Example: Autenticació del servidor (HTTPS, TLS)



Tema 3. Índex

- 3.1 - Conceptes bàsics
- 3.2 - Components d'una PKI
- **3.3 - Models de confiança (trust models)**
- 3.4 - Certificats X.509
- 3.5 - Public-Key Cryptography Standards (PKCS)

Trust models

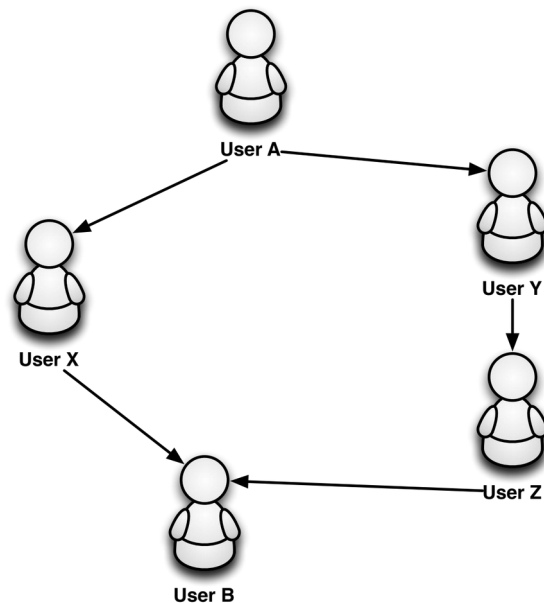
- Model distribuït
- Model pla
- Model jeràrquic
- Models híbrids
 - Model de llista de confiança jeràrquica
 - Model de certificació creuada jeràrquica
 - Model de certificació de pont

Model distribuït

- Model més simple
 - Funciona en una comunitat de pocs usuaris
 - Un usuari crea i firma certificats per a altres usuaris
 - Els usuaris tenen confiança entre ells
 - No necessiten TTP
-
- Pretty Good Privacy (PGP) fa servir aquest model
 - Assumeix que els usuaris són competents per a decidir si confiar entre ells

Exemple de model distribuït

- X afirma (amb una firma) que la clau de B és correcta
- Com A (el verificador) ha firmat el certificat de X, A està segur de que el certificat de B és correcte
- A més, ha trobat una ruta de certificació que creua als usuaris Y i Z



Exemple de model distribuït¹

- L'usuari («you» a la figura) sempre confia amb els agents D, E, F i L per a firmar altres claus
- Confia parcialment amb els usuaris A i B per a firmar altres claus
- Les fletxes mostren qui ha firmat la clave de qui

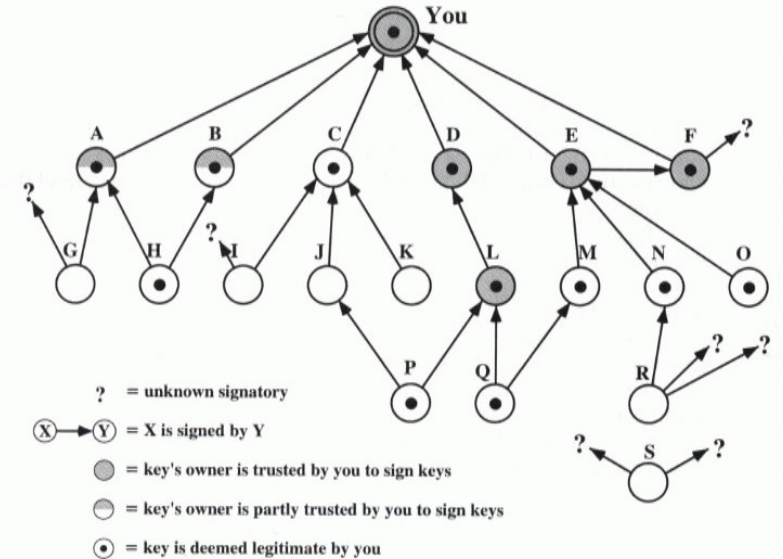
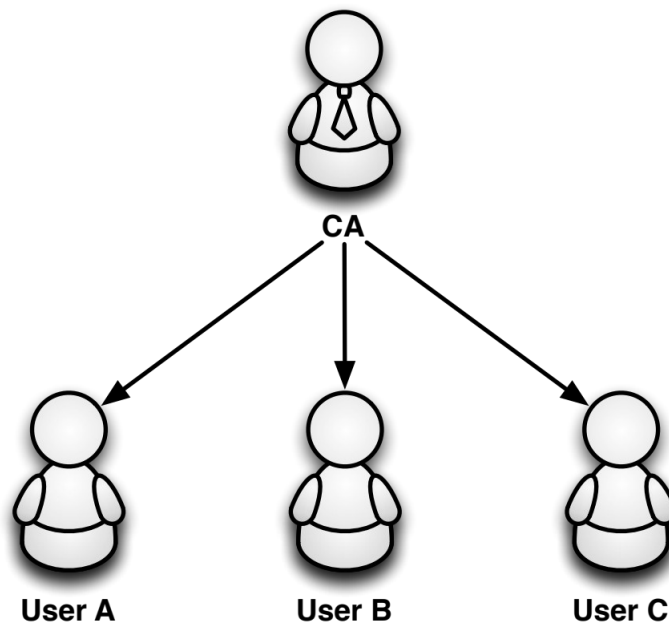


Figure 15.7 PGP Trust Model Example

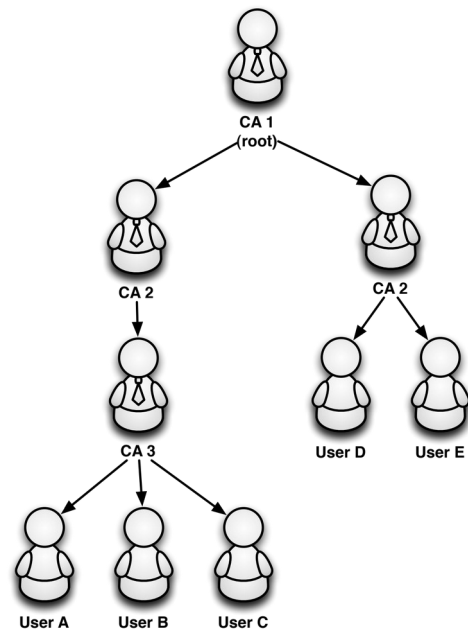
Model Pla

- El model simple, només hi ha una CA que actua com TTP
- Els usuaris validen la identitat dels subscriptors utilitzant el certificat de CA
- El certificat de CA està autosignat



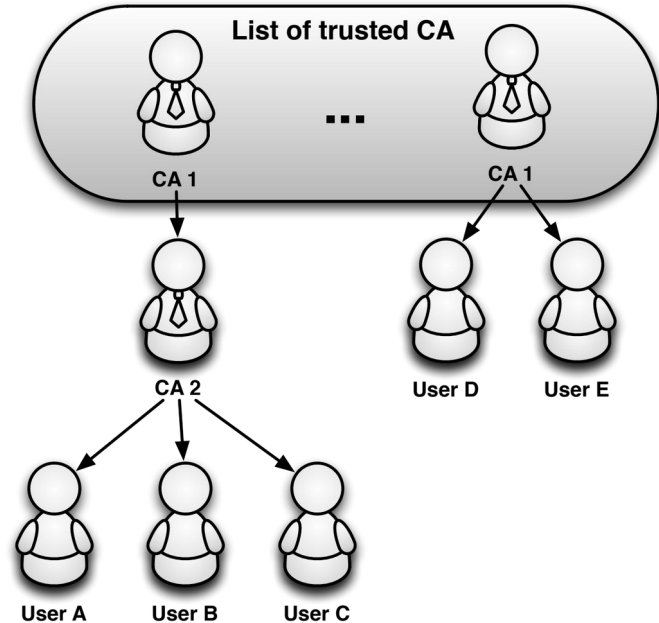
Models Jeràrquics

- Els certificats dels usuaris es firmen mitjançant una TTP
- La TTP està identificada mitjançant un altre certificat emès per una altra CA d'un nivell jeràrquic superior
- Així fins arribar a la CA arrel
- La CA arrel (root) té un certificat autosignat
- Per validar un certificat, es segueix l'àrbre des de avall fins la CA arrel



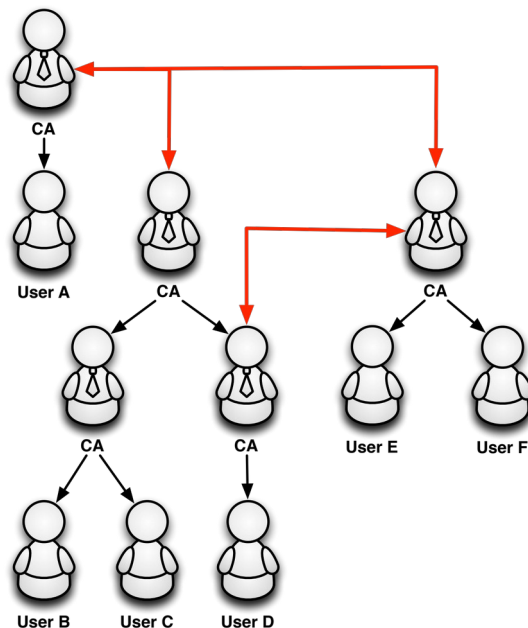
Model híbrid de llista de confiança jeràrquica

- És el model més comú
- Anomenat també model de centre d'usuari
- En aquest cas cada aplicació té una llista de CA de confiança (amb les seves claus públiques)
- S'implementa a la majoria dels navegadors web
- És molt flexible, l'usuari pot agregar/eliminar CA de confiança
- El principal inconvenient és que no hi ha diferència entre PKI bones i no tan bones



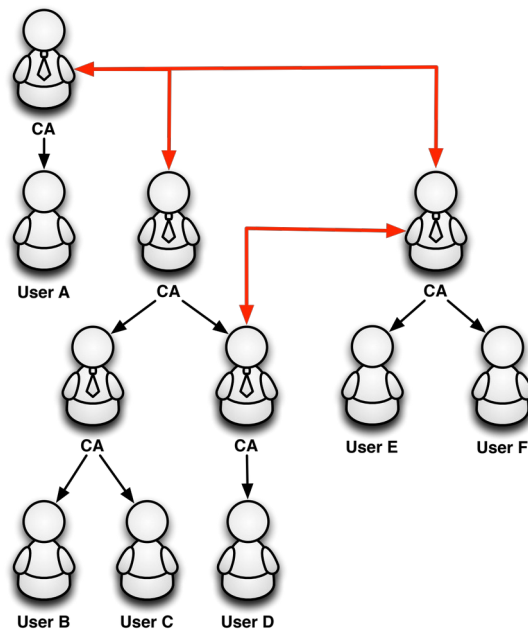
Model híbrid de certificació creuada jeràrquica

- Les CA arrel emeten certificats entre ells
- Aquests certificats certifiquen una CA utilitzant la firma d'una altra CA (certificats creuats)
- Les CA arrel són locals, no globals
- La verificació del certificat pot requerir una cerca costosa
- Com en el model jeràrquic, un usuari confia en una sola CA



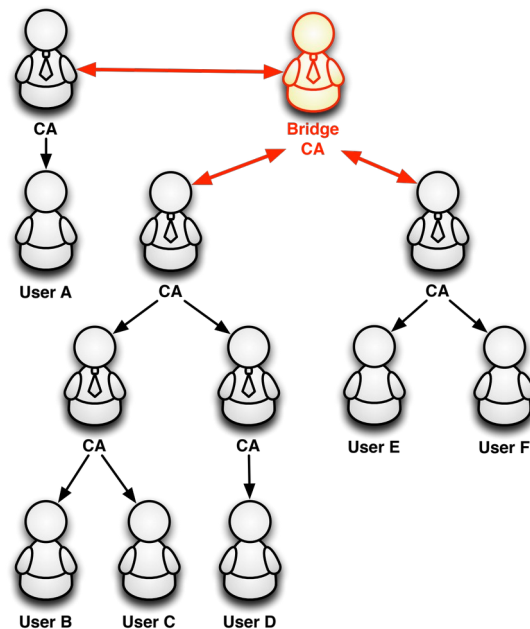
Model híbrid de certificació creuada jeràrquica

- Problema: el número de certificats creuats creix enormement amb el número de CA
- Amb 3 CA, es necessiten 6 certificats creuats
- Amb 100 CA, es necessiten 9,900 certificats creuats



Model híbrid de certificació de pont

- El model CA pont (bridge) redueix la quantitat de certificats necessaris i augmenta la escalabilitat
- Una CA pont és una entitat externa que actua de pont entre dos PKI
- Totes les CA arrel emeten un certificat creuat amb la CA pont
- Per a 3 CA, es necessiten 6 certificats creuats
- Per a 100 CA, es necessiten 200 certificats creuats



Tema 3. Índex

- 3.1 - Conceptes bàsics
- 3.2 - Components d'una PKI
- 3.3 - Models de confiança (trust models)
- **3.4 - Certificats X.509**
- 3.5 - Public-Key Cryptography Standards (PKCS)

Certificats X.509

- Defineix un marc d'autenticació
- També es coneix com PKIX
- Proporciona un estàndard per la certificació de clau pública
- Aspectes principals del format X.509
 - Publicat oficialment el 1998 a partir de la norma X.500
 - Modelo jeràrquic (la v3 inclou models creuats i pont)
 - Mentre X.500 de ITU-T es fa servir poc (intercanvi d'informació entre nacions), X.509 s'ha convertit en l'estàndard a Internet i web
 - Versió 3 actual IETF RFC 5280 (maig 2008)
 - Actualitzada a 6818 (gener 2013), 8398 (maig 2018), 8399 (maig 2018)
 - Inclou aspectes de la PKI, format dels certificats i de les CRLs

Certificats X.509

- Una CA emet un certificat associant a una clau pública i a un **Distinguished Name** (DN)
- Un DN es un conjunto de atributos con un cierto valor
 - Permite a las organizaciones decidir cuáles son los atributos más adecuados para identificar una entidad en una PKI
- Si estos atributos no son suficientes se puede elegir un Nombre Alternativo tal como una dirección de correo electrónico, una entrada de DNS, una @IP

usual attributes	
CN	common name
OU	organization unit
O	organization
C	country
L	location
S	state
STREET	address
T	title

Atributs bàsics

Attribute	Description
version	Identifies the certificate version: v1, v2, v3
serialNumber	Certificate id assigned by the CA
signature	signature algorithm description
issuer	DN of the CA
validity	Two fields defining the time period validity (not before, not after)
subject	DN of the certificate owner
subjectPublicKeyInfo	Information about certificate public key
issuerUniqueId	Allows for CA names re-use (optional)
subjectUniqueId	Allows for owner names re-use (optional)
extensions	Contains all extensions (optional)

Atributs de firma

Attribute	Description
signatureAlgorithm	Contains the hash algorithm: MD2, MD5, SHA-1 and public key algorithm: RSA, DSA used to sign the certificate
signature	Contains the signature value of the basic attributes (including the extensions)

Extensió d'atributs

Attribute	Description
subjectAltName	Owner alternative name (email, ...)
issuerAltName	CA alternative name
keyUsage	Defines and limits certificate usage
basicConstraints	<i>Final entity</i> = 0 or <i>CA</i> = 1, it limits the certification chain length
extKeyUsageSyntax	Complements <i>basicConstraints</i> and <i>keyUsage</i> attributes to set up the usages inside the PKI
nameConstraints	Limit the name space of the next certificates of the chain
issuerAltName	CA alternative name
certificatePolicies	Information about the CPS of the CA
policyMappings	Maps different CA policies
...	...

Exemple

DATA:

Version: 3 (0x2)

Serial Number: 7829 (0x1e95)

Signature Algorithm: md5WithRSAEncryption

Issuer: C=ZA, ST=Western Cape, L=Cape Town, O=Thawte Consulting cc,
OU=Certification Services Division, CN=Thawte Server CA
emailAddress=server-certs@thawte.com

Validity:

Not Before: Jul 9 16:04:02 2011 GMT

Not After: Jul 9 16:04:02 2012 GMT

Subject: C=US, ST=Maryland, L=Pasadena, O=Brent Baccala, OU=FreeSoft,
CN=www.freesoft.org
emailAddress=baccala@freesoft.org

Subject Public Key Info:

Public Key Algorithm:

RSA Public Key:

rsaEncryption

(1024 bit)

Modulus (1024 bit): ...

Exponent: 65537 (0x10001)

La funció de Hash usada
per a firmar

La CA que ha emès i
firmat el certificat

El propietari del certificat

Algorisme, mòdul i
exponent de la clau pública
del propietari del certificat

SIGNATURE:

Certificate Signature Algorithm: md5WithRSAEncryption

Certificate Signature: ...

Firma digital de la CA

Exemple

Certificate: Data: Version: 3 (0x2) Serial Number: 7829 (0x1e95) Signature Algorithm: md5WithRSAEncryption Issuer: C=ZA, ST=Western Cape, L=Cape Town, O=Thawte Consulting cc, OU=Certification Services Division, CN=Thawte Server CA/emailAddress=server-certs@thawte.com Validity Not Before: Jul 9 16:04:02 1998 GMT Not After : Jul 9 16:04:02 1999 GMT Subject: C=US, ST=Maryland, L=Pasadena, O=Brent Baccala, OU=FreeSoft, CN=www.freesoft.org/emailAddress=baccala@freesoft.org Subject Public Key Info: Public Key Algorithm: rsaEncryption RSA Public Key: (1024 bit)

Modulus (1024 bit):

00:b4:31:98:0a:c4:bc:62:c1:88:aa:dc:b0:c8:bb: 33:35:19:d5:0c:64:b9:3d:41:b2:96:fc:f3:31:e1:
66:36:d0:8e:56:12:44:ba:75:eb:e8:1c:9c:5b:66:
70:33:52:14:c9:ec:4f:91:51:70:39:de:53:85:17: 16:94:6e:ee:f4:d5:6f:d5:ca:b3:47:5e:1b:0c:7b:
c5:cc:2b:6b:c1:90:c3:16:31:0d:bf:7a:c7:47:77: 8f:a0:21:c7:4c:d0:16:65:00:c1:0f:d7:b8:80:e3:
d2:75:6b:c1:ea:9e:5c:5c:ea:7d:c1:a1:10:bc:b8: e8:35:1c:9e:27:52:7e:41:8f

Exponent: 65537 (0x10001)

Mòdul i exponent de la
clau pública del
propietari del certificat

Certificate Signature Algorithm: md5WithRSAEncryption Certificate

Certificate Signature:

93:5f:8f:5f:c5:af:bf:0a:ab:a5:6d:fb:24:5f:b6:59:5d:9d:
92:2e:4a:1b:8b:ac:7d:99:17:5d:cd:19:f6:ad:ef:63:2f:92:
ab:2f:4b:cf:0a:13:90:ee:2c:0e:43:03:be:f6:ea:8e:9c:67:
d0:a2:40:03:f7:ef:6a:15:09:79:a9:46:ed:b7:16:1b:41:72:
0d:19:aa:ad:dd:9a:df:ab:97:50:65:f5:5e:85:a6:ef:19:d1:
5a:de:9d:ea:63:cd:cb:cc:6d:5d:01:85:b5:6d:c8:f3:d9:f7:
8f:0e:fc:ba:1f:34:e9:96:6e:6c:cf:f2:ef:9b:bf:de:b5:22: 68:9f

Firma digital de la CA

Exemples



Safari is using an encrypted connection to discussions.apple.com.

Encryption with a digital certificate keeps information private as it's sent to or from the https website discussions.apple.com.

Apple Inc. has identified discussions.apple.com as being owned by Apple Inc. in Cupertino, California, US.

DigiCert High Assurance EV Root CA

Apple Public EV Server RSA CA 2 - G1

discussions.apple.com



discussions.apple.com

Issued by: Apple Public EV Server RSA CA 2 - G1

Expires: Saturday, 12 February 2022 at 22:23:43 Central European Standard Time

This certificate is valid

Trust

Details

Subject Name

Business Category Private Organization

Inc. Country/Region US

Inc. County California

Serial Number C0806592

Country or Region US

County California

Locality Cupertino

Organisation Apple Inc.

Organisational Unit management:idms.group.1208920

Common Name discussions.apple.com

Issuer Name

Country or Region US

Organisation Apple Inc.

Common Name Apple Public EV Server RSA CA 2 - G1

Serial Number 3A AA 0C A4 91 B0 08 AF 73 74 85 75 3C 18 1B 61

Version 3

Signature Algorithm SHA-256 with RSA Encryption (1.2.840.113549.1.1.11)

Parameters None

Not Valid Before Wednesday, 13 January 2021 at 22:23:43 Central European Standard Time

Not Valid After Saturday, 12 February 2022 at 22:23:43 Central European Standard Time

Public Key Info

Algorithm RSA Encryption (1.2.840.113549.1.1.1)

Parameters None

Public Key 256 bytes: EB 2A 53 7D 0C 83 C6 83 ...

Exponent 65537

Key Size 2048 bits

Key Usage Encrypt, Verify, Wrap, Derive

Signature 256 bytes: 7C 62 F2 CE 7D 27 58 9F ...

El propietari del
certificat

La CA que ha emès i
firmat el certificat

Algorisme, mòdul i exponent de la clau
pública del propietari del certificat

Firma digital de la CA

DigiCert High Assurance EV Root CA

DigiCert SHA2 High Assurance Server CA

*wikipedia.org



DigiCert SHA2 High Assurance Server CA

Intermediate certificate authority

Expires: Sunday, 22 October 2028 at 14:00:00 Central European Summer Time

This certificate is valid

Trust

Details

Subject Name

Country or Region US

Organisation DigiCert Inc

Organisational Unit www.digicert.com

Common Name DigiCert SHA2 High Assurance Server CA

Issuer Name

Country or Region US

Organisation DigiCert Inc

Organisational Unit www.digicert.com

Common Name DigiCert High Assurance EV Root CA

Serial Number

04 E1 E7 A4 DC 5C F2 F3 6D C0 2B 42 B8 5D 15 9F

Version 3

Signature Algorithm SHA-256 with RSA Encryption (1.2.840.113549.1.1.11)

Parameters None

Not Valid Before Tuesday, 22 October 2013 at 14:00:00 Central European Summer Time

Not Valid After Sunday, 22 October 2028 at 14:00:00 Central European Summer Time

Public Key Info

Algorithm RSA Encryption (1.2.840.113549.1.1.1)

Parameters None

Public Key 256 bytes: B6 E0 2F C2 24 06 C8 6D ...

Exponent 65537

Key Size 2048 bits

Key Usage Encrypt, Verify, Derive

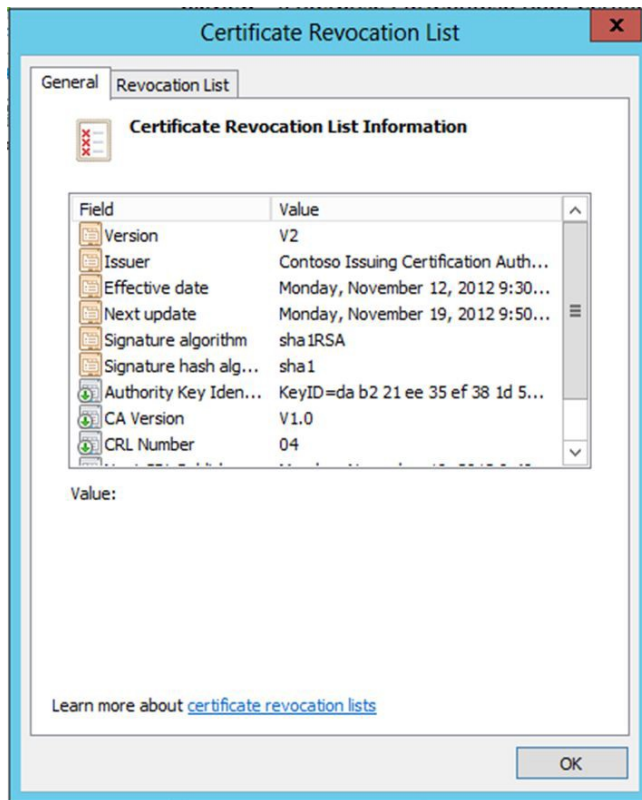
Signature 256 bytes: 18 8A 95 89 03 E6 6D DF ...

Certificats X.509

- Una CRL és una estructura de dades firmada per una CA
- Conté les dades essencials per a determinar el estat del certificat
- Atributs bàsics de les CRLs

Attribute	Description
version	Identifies the CRL version: v1 or v2
signature	Signature algorithm description
issuer	DN of the signing CA (usually the same who issues the list)
thisUpdate	Issue date
nextUpdate	Next issue date
revokedCertificates	List of revoked certificates
crlExtensions	Contains extensions related to the CRL (optional)

Exemple de Certificate Revocation List



Tema 3. Índex

- 3.1 - Conceptes bàsics
- 3.2 - Components d'una PKI
- 3.3 - Models de confiança (trust models)
- 3.4 - Certificats X.509
- **3.5 - Public-Key Cryptography Standards (PKCS)**

Public-Key Cryptography Standards

- Grups de estàndards promoguts per RSA Security LLC des de 1991
 - Empresa que promou l'ús de les tècniques de criptografia
 - Té les patents dels algorismes RSA, de l'algorisme de firma Schnorr i de molts altres
- No són estàndards (la empresa reté el control sobre ells)
- Però s'han convertit en estàndards de facto
 - Empreses com Apple, Microsoft, Facebook, etc. l'han adoptat
 - Grups de treball a l'IETF i PKIX

Public-Key Cryptography Standards

- Es numeren de l'1 al 15
 - PKCS#1, PKCS#2, ..., PKCS#15
- Realment en l'actualitat se'n fan servir només 10:
 - PKCS#1; #3; #5; #7; #8; #9; #10; #11; #12; #15
 - PKCS#13 (elliptic curves) i #14 (pseudorandom numbers generation) s'han abandonat
 - PKCS#2 (xifrat de resums de missatges) i #4 (sintaxis de la clau) s'han integrat a PKCS#1
 - PKCS#6 (extensions per a X.509v1) s'ha deixat d'usar a favor del certificat X.509v3
 - Llista actualitzada a: <https://en.wikipedia.org/wiki/PKCS>

Public-Key Cryptography Standards

PKCS	Description	Standard IETF
1	Defines encryption and signature protocols for RSA. It includes a syntax (equal to X.509) for private and public keys	RFC 8017
3	Defines a Diffie-Hellman key agreement	
5	Defines a protocol to encrypt a text m with a private key obtained from the hash of a pass phrase p . $E_{H(p)}(m) = c$. H is MD2 or MD5	RFC 8018
7	Defines the syntax of an encrypted and(or) signed message	RFC 2315 i RFC 5652
8	Defines the information format of a private key	RFC 5958
9	Defines attribute types for PKCS standards	RFC 2985
10	Defines the format of a certification request	RFC 2986
11	Defines the Cryptoki interface, an independent programming language for smart cards	

Public-Key Cryptography Standards

PKCS	Description	Standard IETF
12	Defines a portable format to store private keys, certificates, ...	RFC 7292
13	Define methods to encrypt and sign messages with elliptic curves cryptography	Abandonat
14	Devoted to pseudorandom numbers generation	Abandonat
15	Complements <i>PKCS#11</i> defining the format of the cryptographical credentials stored into cryptographical devices	ISO/IEC 7816-15

PKCS#7

- Cryptographic Message Syntax Standard
- Versió 1.5
- IETF RFC 5652 (Set. 2009) y RFC 8933 (Des. 2020)
- Defineix la sintaxi dels missatges xifrats i/o firmats
- Generalment es fa servir per a
 - firmar i/o xifrar missatges sota una PKI
 - la difusió de certificats
 - l'inici de sessió única (single sign-on)

Elements de PKCS#7

- **Data**
 - Informació sense firmar
- **SignedData**
 - Informació firmada digitalment
- **EnvelopedData**
 - Informació per a un grup de destins
 - Es crea un sobre digital per a cada destí
 - Es genera (aleatòriament) una clau simètrica i es xifra la informació (xifrat simètric)
 - Es xifra la clau simètrica amb la clau pública de cada destí (xifrat asimètric)
 - Cada destí podrà treure la clau del xifrat simètric usant la seva clau privada (xifrat asimètric)
 - Amb la clau privada del xifrat simètric podrà desxifrar la informació

Elements de PKCS#7

- **SignedAndEnvelopedData**

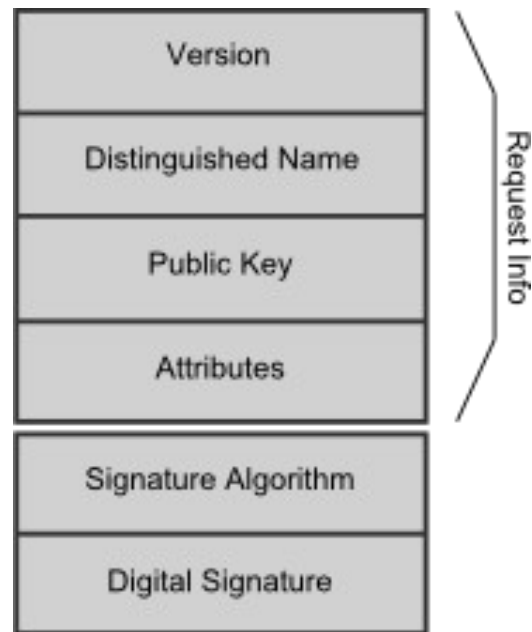
- Informació doblement xifrada
- Es firma la informació amb la clau privada (xifrat asimètric)
- Es genera (aleatòriament) una clau simètrica i es xifra la informació (xifrat simètric)
- Es xifra la clau simètrica amb la clau pública de cada destí (xifrat asimètric)
- Cada destí podrà treure la clave simètrica fent servir la seva clau privada (xifrat asimètric)
- El destí amb la clau simètrica podrà desxifrar la informació
- I amb la clau pública de l'origen verificar qui ha firmat

Elements de PKCS#7

- **EncryptedData**
 - Informació xifrada per a cap destinatari concret
- **DigestedData**
 - Es calcula un resum de la informació (per exemple funció de Hash)
 - Es junta a la informació i el seu resum
 - Aquesta unió es pot usar després com input d'altres tipus

PKCS#10

- Certification Request Standard
- Defineix el format d'una sol·licitud de certificat
 - Una sol·licitud de certificat consta d'un nom, una clau pública i un conjunt opcional de atributs d'usuari (per exemple, una clau de revocació)
- Versió: PKCS#10
- DN de l'usuari
- Informació sobre la clau pública
- Informació addicional sobre l'usuari



PKCS#12

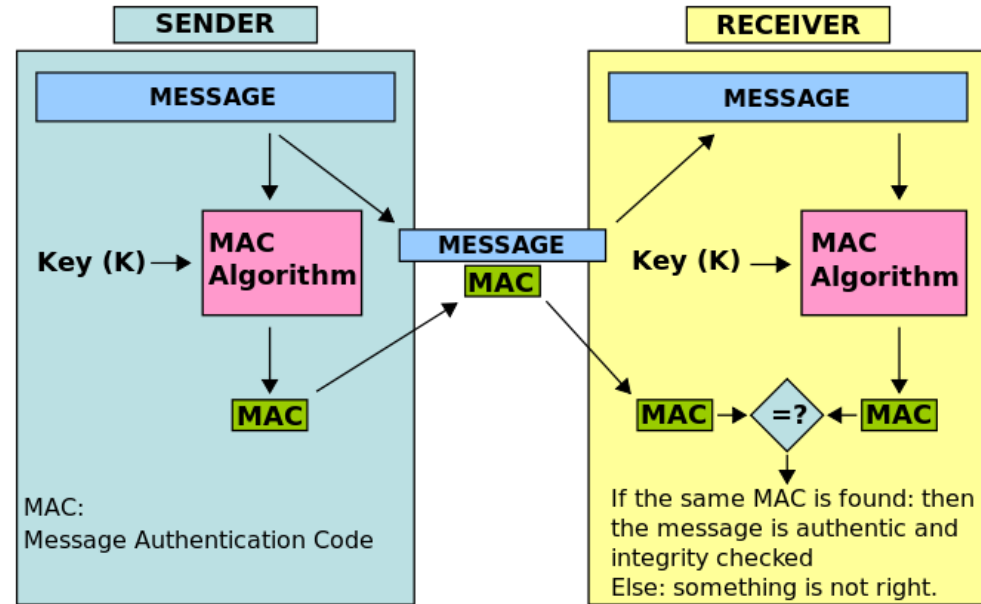
- Personal Information Exchange Syntax Standard
- Versió 1.1
- IETF RFC 7292 (Juliol 2014)
- Descriu el format per a la transferència d'informació personal, que pot incloure claus privades, certificats, extensions, etc.
 - En principi, les aplicacions que admeten aquest format permeten un intercanvi segur de dades

PKCS#12

- Té quatre modes diferents depenent de si l'usuari vol privacitat o integritat:
- **Public key privacy:** la informació personal s'empaqueta i es xifra al repositori d'origen amb la clau pública del repositori de destí
- **Password privacy:** la informació personal està empaquetada i xifrada amb nombre d'usuari i contrasenya
- **Public key integrity:** la integritat es proporciona mitjançant una firma amb la clau privada del repositori d'origen
 - El destí verifica la informació usant la clau pública de l'origen
- **Password integrity:** la integritat es garanteix utilitzant un còdi d'autenticació del missatge (MAC) derivat d'una contrasenya d'integritat de l'origen
 - Només el pot verificar qui tingui la informació xifrada i la contrasenya

PKCS#12: MAC: Message Authentication Code

- Paregut a una funció de Hash
- Usat per a validar la integritat de cada missatge



Modes a PKCS #12

- Es recomana utilitzar els modes amb clau pública
 - Una contrasenya pot no ser suficient
 - Però els modes amb contrasenya són els únics viables si no es té la clau pública del destinatari

Format

PKCS#12	Description
version	PKCS#12 message version used
authSafe	PKCS#7 structure containing a <i>signedData</i> attribute when public key method is used or <i>data</i> otherwise
macData	It is only used when integrity is granted by means of a password
mac	PKCS#7 digestData
macSalt	random seed for the hash
iterations	Not in use, it is only for historical reasons

Seguretat Informatica (SI)

Infraestructura PKI

René Serral (forked from: Davide Careglio)

Fonts:

Jordi Nin, "Certificates", Computer Security, 2014

Francisco Jordan, "PKI and Certificates", Computer Security, 2018

Jaime Delgado, "Certificates", Computer Security, 2017